

**Universidad Nacional de Ingeniería
Facultad de Ciencias**

Arquitectura de computadores

Seguridad Informática

Prof.: Lic. César Martín Cruz S.
ccruz@uni.edu.pe

Seguridad Informática

La **seguridad informática**, también conocida como **ciberseguridad**, es un conjunto de procesos, procedimientos, tareas y actividades implementados conjuntamente con elementos de computación y telecomunicaciones para controlar y proteger contra amenazas que pongan en riesgo los recursos informáticos (información, equipos, etc.) ubicados en un sitio específico, durante su estadía en un medio de almacenamiento o durante su transmisión, en sus aspectos de integridad, disponibilidad, confidencialidad y autenticidad.

Para ello existen una serie de estándares y herramientas concebidas para minimizar los posibles riesgos a la infraestructura o a la información.

La **ciberseguridad** también se refiere a la práctica de defender de ataques maliciosos, los computadores, servidores y las redes.

Ciberseguridad

El gobierno de Estados Unidos invierte USD 13000 millones al año en ciberseguridad, pero advierte que los ciberataques siguen evolucionando con gran rapidez. Para contrarrestar la proliferación de código malicioso y ayudar en la detección temprana, el Instituto Nacional de Estándares y Tecnología (NIST) recomienda el monitoreo continuo y en tiempo real de todos los recursos electrónicos.

Ciberseguridad

La seguridad informática debe establecer normas que minimicen los riesgos a la información o infraestructura informática. Estas normas incluyen horarios de funcionamiento, restricciones a ciertos lugares, autorizaciones, denegaciones, perfiles de usuario, planes de emergencia, protocolos y todo lo necesario que permita un buen nivel de seguridad informática.

Activos Informáticos

- **La infraestructura computacional:** se utiliza para el almacenamiento y gestión de la información, así como para el funcionamiento mismo de la organización. La función de la seguridad informática en esta área es velar por que los equipos funcionen adecuadamente y anticiparse en caso de fallos, robos, incendios, sabotajes, desastres naturales, fallos en el suministro eléctrico y cualquier otro factor que atente contra la infraestructura informática.

Activos Informáticos

- **Los usuarios:** son las personas que utilizan la estructura tecnológica, zona de comunicaciones y que gestionan la información. Debe protegerse el sistema en general para que el uso por parte de ellos no pueda poner en entredicho la seguridad de la información y tampoco que la información que manejan o almacenan sea vulnerable.
- **La información:** esta es el principal activo. Utiliza y reside en la infraestructura computacional y es utilizada por los usuarios.

Amenazas

Son tres: **el cibercrimen**, que incluye actores individuales o grupos que dirigen ataques a sistemas para obtener ganancias financieras; **la ciberguerra**, que a menudo involucra recopilación de información con motivaciones políticas; y el **ciberterrorismo**, cuyo propósito es comprometer los sistemas electrónicos y causar pánico o temor. Los métodos comunes que usan los **ciberatacantes** para controlar las computadoras o redes incluyen virus, gusanos, spyware y troyanos.

Amenazas

Los virus y los gusanos se pueden autorreplicar y dañar archivos o sistemas, en tanto que el **spyware** (software espía) y los troyanos a menudo se utilizan para la recopilación subrepticia de datos. En general, un usuario promedio entra en contacto con código malicioso a través del archivo adjunto de un correo electrónico no solicitado o cuando descarga programas que parecen legítimos, pero de hecho contienen una carga de **malware** (software malicioso). Perjudican o hacen un uso ilícito de los recursos del sistema. Es instalado en el ordenador, abriendo una puerta a intrusos o bien modificando los datos.

Amenazas

Usuarios: Causa del mayor problema ligado a la seguridad de un sistema informático. En algunos casos sus acciones causan problemas de seguridad, si bien en la mayoría de los casos es porque tienen permisos sobredimensionados, no se les han restringido acciones innecesarias, etc.

Errores de programación: la mayoría de los errores de programación que se pueden considerar como una amenaza informática es por su condición de poder ser usados como exploits por los crackers, aunque se dan casos donde el mal desarrollo es, en sí mismo, una amenaza. La actualización de parches de los sistemas operativos y aplicaciones permite evitar este tipo de amenazas.

Intrusos: personas que consiguen acceder a los datos o programas a los cuales no están autorizados (crackers, hackers, script kiddie o script boy, viruxers, etc.).

Otras amenazas

Un siniestro (robo, incendio, inundación): una mala manipulación o intención derivan en la pérdida del material o de los archivos.

Personal técnico interno: técnicos de sistemas, administradores de bases de datos, técnicos de desarrollo, etc. Los motivos que se encuentran entre los habituales son: disputas internas, problemas laborales, despidos, fines lucrativos, espionaje, etc.

Phishing puede llegar a robar la contraseña de un usuario de una red social y con ella realizar una suplantación de la identidad para un posterior acoso, o el robo de la contraseña puede usarse simplemente para cambiar la foto del perfil y dejarlo todo en una broma.

Requerimientos de seguridad

- **Disponibilidad:** Es la garantía de que la información será accesible por los usuarios a los servicios de la red según su “perfil” en el momento requerido y sin “degradaciones”. (perfil: depende de que requieren para su desempeño laboral en la empresa)
- **Integridad:** Tiene que ver con la protección que se da a los activos informáticos para que solo puedan ser modificados por las personas autorizadas: Escritura, Cambio de información, cambio de estatus, borrado y creación. Es diferente para c/empresa.
- **Confidencialidad o Privacidad:** “Propiedad o requerimiento de la seguridad que exige que la información sea accedida por cada usuario en base a lo que debe ver en razón a su área del negocio” .
- **Autenticidad:** Propiedad fundamental de la información de ser confrontada en cualquier momento de su ciclo de vida contra su origen real (Verdadero/falso). Especialmente importante en sistemas económicos (banca, comercio electrónico, bolsa de valores, apuestas, etc.)

Roles de Seguridad

Se encuentran básicamente 4 roles de seguridad a saber:

- **Administrador de seguridad:** Es la persona encargada dentro de una organización de analizar, diseñar, desarrollar, implantar, probar y mejorar los mecanismos de seguridad que se requieren para proteger los activos informáticos de dicha organización. Es el responsable de que la seguridad sea efectiva y de realizar permanentemente revisiones de esta en pro de su mejoramiento continuo. El trabajo que realiza en algunas ocasiones lo hace con el apoyo de consultores o asesores de apoyo y con un grupo de expertos en seguridad a su cargo dentro de la organización.
- **Auditor, asesor, consultor:** Son generalmente personas externas a la organización que realizan revisiones a la seguridad implantada y realizan recomendaciones para su mejoramiento. Son personas de apoyo para el administrador de seguridad porque le pueden dar consejos de implantaciones de seguridad, hacerlo caer en la cuenta de falencias de seguridad y apoyarlo en nuevos diseños e implantaciones al respecto.
- **Forense:** Son expertos que se encargan de realizar análisis de siniestros de seguridad ocurridos dentro de la organización para determinar lo que paso y quién lo hizo, y si es el caso, aportar en procesos penales contra los atacantes

Roles de Seguridad

- **Atacante:** Son las personas que buscan tener acceso ilegal a los activos informáticos de una organización. En este rol se pueden distinguir tres tipos:
 - **Hacker:** Son personas expertas en sistemas que saben de seguridad que lo que buscan es tener acceso a recursos informáticos generalmente con el fin de demostrarse a sí mismo y a otros que lo pudieron hacer y conseguir prestigio como expertos en seguridad.
 - **Cracker:** Son igualmente personas expertas en sistemas y que saben de seguridad y buscan tener acceso a los recursos informáticos con el objetivo de hacer daño a las organizaciones y obtener algún tipo de recompensa, por ejemplo robar datos de una empresa para vendérsela a la competencia, desprestigiar a la organización, robar dinero, etc.
 - **Lamers:** Esta es una nueva categoría, se trata de personas que no saben mucho de los sistemas de seguridad y se dedican a utilizar herramientas o aplicaciones desarrolladas por otros (hackers o crackers) para hacer daño a las organizaciones. Los lamers no saben de la técnica que hay detrás de un ataque o un mecanismo de violación de un sistema, solo siguen instrucciones respecto al uso de algunas herramientas y realizan fechorías con esto. Este tipo de atacantes puede hacerlo por el simple placer de hacerlo o con ánimo de obtener alguna retribución por sus acciones.